

▶情報セキュリティ

- [1. 情報セキュリティの考え方](#)
- [2. コンピューターウィルスとサイバー攻撃](#)
- [3. 暗号化とデジタル署名](#)
- [4. ネットワークセキュリティ](#)
- [5. ネットワークセキュリティ過去問演習](#)
- 用語集

用語	フルネーム	意味
情報セキュリティ上の重大な欠陥セキュリティホール	-	OSやソフトなどにおいて、設計上の不具合、プログラムのミスにより発生する
ソーシャルエンジニアリング	-	人の心理の隙をついて機密情報を入力する行為
不正のトライアングル	-	機会・動機・正当化 機会：自分以外のパソコンにログインできてしまう 動機：営業ノルマのプレッシャー 正当化：不正を働いても仕方がない、会社のためでもある
ISMS	Information Security Management System	ISMS適合評価制度。情報セキュリティを管理する仕組み
JIS Q 27000	-	用語の定義
JIS Q 27001	-	ISMS認証評価事故
JIS Q 27004	-	情報セキュリティガバナンス
情報セキュリティの3大要素	-	機密性：許可された人だけが情報にアクセスできるようにすること 安全性：情報が正確・安全であること 可用性：利用者が必要な時にいつでも情報にアクセスできること 真正性：偽造やなりすましがなく情報が本物であること 信頼性：意図した通りの結果が返ってくること 責任追跡性：誰が関与したか追跡ができるようにすること 否認防止性：あとで「自分ではない」と否定されないようにすること
マルウェア	-	コンピューターに悪影響を与えるソフトウェアの総称

用語	フルネーム	意味
コンピューターウイルス	-	他のプログラムに寄生しながらコンピューターに悪影響を与えるウィルス
マクロウイルス	-	ExcelやWordなどのマクロ機能を悪用して感染するウィルス
ワーム	-	自己増殖機能を持ち、自ら感染を広めていくウィルス
トロイの木馬	-	有益なソフトウェアと見せかけてユーザーに実行を促し、その裏で不正操作をするウィルス
スパイウェア	-	他ソフトに紛れてコンピューターにインストールされ、利用者の情報を抜き取るウィルス
ランサムウェア	-	(ランサム
キーロガー	-	キーボード操作を不正に記録して利用者の個人情報を抜き取ること
ルートキット	-	(バックドア
ボット	-	ウィルス感染した情報機器を外部から不正に操作するプログラム
C&Cサーバー	-	遠隔操作をするために命令を出すサーバー
ゾンビ	-	ウィルスに感染して不正に操作されるコンピューター
ビヘイビア法	-	メモリ上の仮想環境で検査対象のプログラムを実際に動かし、その挙動からマルウェアを検知する。未知ウィルスの検知も可能。※誤った検知をすることもある
パターンマッチング法	-	既存のウィルスのパターン（シグネチャコード）と検査対象プログラムを比較してマルウェアを検知する。未知ウィルスの検知は不可能
辞書攻撃	-	パスワードに何かしら単語を使用する人が多いことを悪用し、辞書に載っている単語でパスワードを推測する手法
ブルートフォース攻撃/総当たり攻撃	-	IDを1つ定め、パスワードとして使用可能な文字を総当たりで試す手法
リバースブルートフォース攻撃/総当たり攻撃	-	パスワードを1つ定め、IDとして使用可能な文字を総当たりで試す手法
パスワードリスト攻撃	-	他のサイト等で不正に入手したパスワードとIDを用いてログインを試す手法。IDとパスワードを複数のサイトで使いまわす人を狙った攻撃
レインボー攻撃	-	不正に入手したパスワードのハッシュ値（あるデータを特定のアルゴリズム（ハッシュ関数）で変換したもの（データ➡ハッシュ値〇、不可逆））から元のパスワードを推測する手法

用語	フルネーム	意味
クロスサイト クリプティング	-	正規のWebサイト上に偽のWebページを表示させる手法。問い合わせフォーム等の偽サイトを表示して利用者に個人情報を入力させることで情報を抜き取る
SQLインジェクション	-	(インジェクション: 注入) SQLの中に不正な命令を紛れ込ませ、データベースを不当に操作する手法。データの漏洩やデータベースの破壊等の被害が想定される
OSコマンド インジェクション	-	ユーザーがWebサイトに入力したデータにOSへの命令文(コマンド)を紛れ込ませる手法。OS操作コマンド(ファイルの削除や書き換え等)を不正操作され、情報漏洩等に繋がる
ディレクトリ リリスティング	-	Webサイトを構成するディレクトリやファイルの一覧をすべて表示させる攻撃(ユーザーに公開していないファイルも表示されてしまう)
ディレクトリ リトラバーサル	-	(トラバーサル: 横断、縦走、走査) Webの非公開ファイルに不正にアクセスし、ファイルの閲覧や削除などを実施する攻撃
DNSキャッシュ ポイズニング	-	ドメインとIPアドレスを結びつけるDNSサーバーに偽サイトのドメインを紛れ込ませ、利用者を偽サイトに誘導する手法
フィッシング	-	金融機関などを装った電子メールを送信して偽サイトに誘導し、使用者から個人情報を抜き取る手法
セッション ハイジャック	-	利用者がWebサイトにログインした際に発行されるセッションIDをはく奪し、そのIDを用いて利用者になりすます手法
SEOポイズ ニング	Search Engine Optimization	SEO(Webサイトの掲載順位を決定するアルゴリズム)を悪用し、悪意のあるWebサイトが検索上位に表示されるようにすること(Googleで某銀行を検索したが一番上に出てきたのは偽サイト)
IPスプー フィング	-	攻撃者のIPアドレスを正規のアドレスに詐称してサイトに不正アクセスする手法
ドライブバイ ダウンロード	-	Webサイトを閲覧しただけでマルウェアを閲覧者のPCにダウンロードさせる手法
バッファオ ーバフロー	-	サーバーの処理能力を超える大容量データ等を送り付け、サービスを停止させる攻撃
Dos攻撃	-	特定のWebサイトに対して大量のアクセスを行い、サーバー機能を停止させること(攻撃者PCが1台)
DDos攻撃	-	特定のWebサイトに対して大量のアクセスを行い、サーバー機能を停止させること(攻撃者PCが複数台)

用語	フルネーム	意味
共通鍵暗号方式	-	(盗聴を防ぐ手法) 暗号化と復号で 同じ鍵 を使用し、鍵を 秘密 にしておく
公開鍵暗号方式	-	(盗聴を防ぐ手法) 暗号化と復号で 別々の鍵 を使用し、暗号化用の鍵を 公開 する
ハッシュ関数 メッセージダイジェスト	-	(改ざん防ぐ手法) 入力データにハッシュ関数 (SHA-256) を利用して出力されたデータはハッシュ値
デジタル署名	-	(改ざん・なりすましを防ぐ手法) ハッシュ化及び公開暗号方式の逆手順で デジタル署名 を実施することで改ざんとなりすましを防ぐ
認証局とPKI (公開鍵基盤)	Public Key Infrastructure	公開鍵 が本人のものであることを 証明 する認証機関を認証局 (CA:Certification Authority)
ファイアウォール	-	内部ネットワーク と 外部ネットワーク の間で機能する、外部からの不正アクセスを防ぐ仕組み
パケットフィルタリング	-	パケットのヘッダ情報 で 通信可否 を制御する方法
ホワイトリスト	-	通過許可 IPアドレスを設定
ブラックリスト	-	通過禁止 IPアドレスを設定
プロキシサーバー	-	内部から外部へ のアクセスを 代理実施 するサーバー
リバースプロキシサーバー	-	外部から内部へ のアクセスを 代理実施 するサーバー
DMZ	DeMilitarized Zone	内部・外部から切り離されたネットワーク をDMZと呼び、自社サイトのWebサーバーなど外部に公開するサーバーを設置
WAF	Web Application Firewall	Webアプリケーション への攻撃を防ぐ仕組み
バイオメトリクス認証	-	(Biometric : 生体認証) 指紋認証、顔認証、音声認証など 身体的特徴 を用いて本人確認をする方法
ワンタイムパスワード	-	一定時間ごとに発行され、 一度きりしか使用出来ないパスワード (一回しか使用しないため、仮にパスワードを盗まれても問題ない)

用語	フルネーム	意味
CAPTCHA/ reCAPTCHA	-	コンピューターでは識別不可能な文字や画像をユーザーに回答させ、ユーザーがコンピューターbotではないことを証明する方法
VPN	Virtual Private Network	ネット回線上に特定の人だけがアクセスできる仮想的な専用機を引き、通信の安全性を高める方法
SSL	Secure Sockets Layer	インターネットの通信を暗号化するプロトコルであり、クレジットカード等の機密情報を送る際に使用される（※ SSLの次世代規格をTLSと呼び、あまり区別されない）
ペネトレーションテスト	-	（Penetration：浸透/ 侵入）システムの脆弱性を検知するため、システムに対して実際に攻撃を仕掛け、セキュリティレベルをチェックすること（攻撃する人をホワイトハッカーと呼ぶ）
ファuzzing	-	（Fuzz：毛羽/ 綿毛 ⇒ けばだたせる/ ぼやけさせる）ソフトウェアの脆弱性を検知するため、プログラムに対して異常を引き起こす可能性がある多様なデータを自動入力してチェックすること
HTTP	-	Webサーバーとブラウザ間で情報を通信する際に使用されるプロトコル
HTTPS	-	HTTP over SSL/TLSの略で、SSL/TLSを用いてHTTP通信を暗号化したプロトコル
IP	-	TCP/IPモデル第2層で使用され、データを正しいアドレスに送るためのプロトコル
IPsec	-	IPプロトコルを拡張し暗号化を実現するプロトコル
TELNET	-	現在のコンピューターから別のコンピューターを遠隔操作するプロトコル
SSH	-	現在のコンピューターから別のコンピューターを暗号化通信で安全に遠隔操作するプロトコル

パスワードクラック	脆弱性を狙う攻撃	なりすまし攻撃	パソコンへの攻撃
- 辞書攻撃 - ブルートフォース攻撃 - リバースブルートフォース攻撃 - パスワードリスト攻撃 - レインボー攻撃 	- クロスサイトスクリプティング - SQLインジェクション - OSコマンドインジェクション - ディレクトリリストイング - ディレクトリトラバーサル 	- DNSキャッシュポイズニング - フィッシング - セッションハイジャック - SEOポイズニング - IPスプーフィング 	- ドライブバイダウンロード - バッファオーバーフロー - DoS攻撃 - DDoS攻撃 
パスワードを見破る攻撃	OSやWebサイトの脆弱性を狙って実施される攻撃	攻撃者が正規利用者になりすまし情報等を騙し取る攻撃	パソコンやサーバに対して負荷やマルウェアを送り込む攻撃

- 【共通鍵暗号方式（秘密鍵暗号）】

>>> 送信側 <<<

↓

① 共通鍵（秘密鍵）で暗号化

↓
② 暗号文を送信
↓
>>> 受信側 <<<
↓
③ 同じ共通鍵で復号

- 【公開鍵暗号方式（秘密鍵暗号）】

>>> 送信側 <<<
↓
① 受信側の「公開鍵」で暗号化
↓
② 暗号文を送信
↓
>>> 受信側 <<<
↓
③ 自分の「秘密鍵」で復号

- 【デジタル署名（改ざん防止＋本人確認）】

>>> 送信側 <<<
↓
① メッセージのハッシュ値を作る
↓
② 自分の「秘密鍵」で署名（暗号化）
↓
③ メッセージ + 署名 を送信
↓
>>> 受信側 <<<

↓
④ 送信者の「公開鍵」で署名を復号
↓
⑤ 自分で計算したハッシュ値と比較

📖 情報セキュリティの考え方

- 情報セキュリティ

- インターネットの発達により、サーバー攻撃や情報漏洩のリスクも増えてきたため、重視すべき項目となってきた
- 脆弱性
 - OSやソフトなどにおいて、設計上の不具合、プログラムのミスにより発生する情報セキュリティ上の重大な欠陥（セキュリティホール）
 - コンピューターウイルスの攻撃に利用される
- 脅威
 - 情報資産を脅かす
 - 物理的脅威：地震や火災などの災害による故障、侵入者による装置の破壊
 - 人的脅威：操作ミス、情報の不正利用、怠慢・不注意
 - ソーシャルエンジニアリング：人の心理の隙をついて機密情報を入力する行為
 - 画面を覗く
 - ゴミ箱から機密情報を抜き出す
 - 不正のトライアングル：機会・動機・正当化
 - 機会：自分以外のパソコンにログインできてしまう
 - 動機：営業ノルマのプレッシャー
 - 正当化：不正を働いても仕方がない、会社のためでもある
 - 技術脅威：コンピューターウイルス、サイバー攻撃

- 情報セキュリティマネジメント

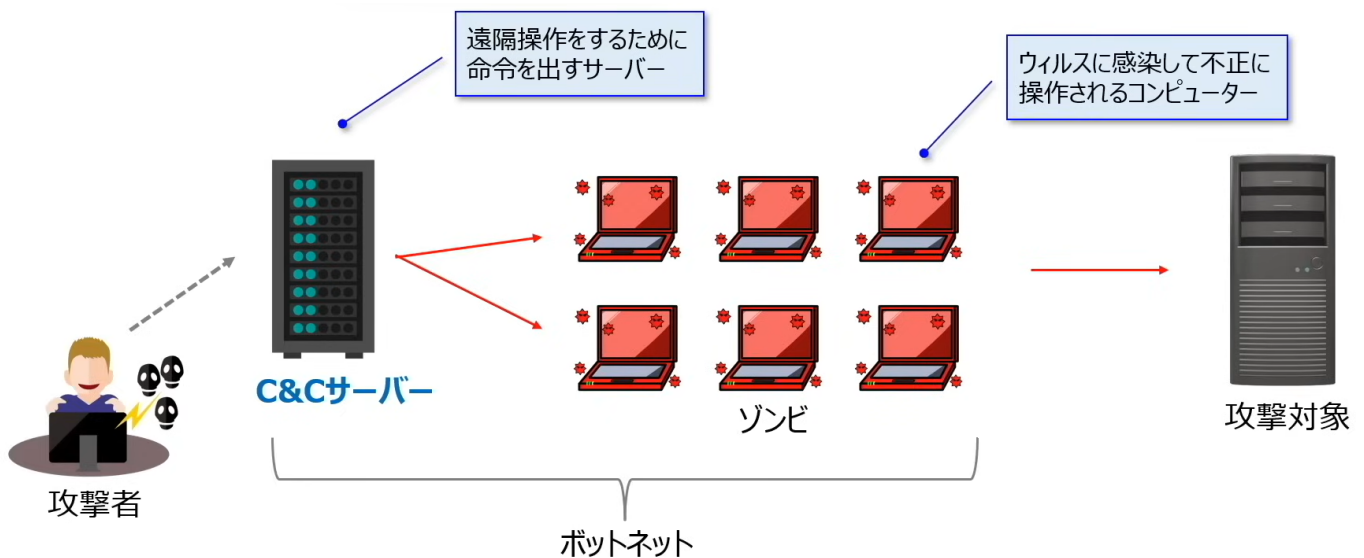
- ISMS（Information Security Management System）
 - ISMS適合評価制度。情報セキュリティを管理する仕組み
 1. 情報セキュリティに関する評価事項が定められており、第三者がこの評価事項に沿って企業の情報セキュリティを評価する
 2. その評価が高かった企業は情報を安全に取り扱っていると認められ、ISMS認証というものが発行される
 - ISMS認証を持つ会社は、すなわち情報セキュリティ意識が高いということ。消費者/取引先企業が安心して個人情報を提供できる
 - JIS Q 27000シリーズ：情報セキュリティに関する評価事項を定義する
 - JIS Q 27000：用語の定義
 - JIS Q 27001：ISMS認証評価事故
 - JIS Q 27004：情報セキュリティガバナンス
 - 情報セキュリティの3大要素
 - 機密性：許可された人だけが情報にアクセスできるようにすること
 - 安全性：情報が正確・安全であること
 - 可用性：利用者が必要な時にいつでも情報にアクセスできること
 - 真正性：偽造やなりすましがなく情報が本物であること
 - 信頼性：意図した通りの結果が返ってくること。意図する行動と結果とが一貫している

- 責任追跡性：誰が関与したか追跡ができるようにすること
 - 否認防止性：あとで「自分ではない」と否定されないようにすること
-

📖 コンピューターウイルスとサイバー攻撃

• マルウェア

- コンピューターに悪影響を与えるソフトウェアの総称（コンピューターウイルスはマルウェアの1種）
 - **コンピューターウイルス**：他のプログラムに寄生しながらコンピューターに悪影響を与えるウイルス
 - **マクロウイルス**：ExcelやWordなどのマクロ機能を悪用して感染するウイルス
 - **ワーム**：自己増殖機能を持ち、自ら感染を広めていくウイルス
 - **トロイの木馬**：有益なソフトウェアと見せかけてユーザーに実行を促し、その裏で不正操作をするウイルス
 - **スパイウェア**：他ソフトに紛れてコンピューターにインストールされ、利用者の情報を抜き取るウイルス
 - **ランサムウェア**：（ランサム：身代金）利用者PCのファイル勝手に暗号化し、暗号化の解除と引き替えに金銭を要求すること
 - **キーロガー**：キーボード操作を不正に記録して利用者の個人情報を抜き取ること
 - **ルートキット**：（バックドア：攻撃者がこっそりと作るWebサイトへの侵入経路（バックドアからのアクセスは検知できない））バックドア生成ツールやログ改ざんツールなど、コンピューターへの不正アクセスに有用なツールがパッケージとしてまとめられたもの
 - **ボット**：ウイルス感染した情報機器を外部から不正に操作するプログラム
 - **C&Cサーバー**：遠隔操作をするために命令を出すサーバー
 - **ゾンビ**：ウイルスに感染して不正に操作されるコンピューター



• ウィルス対策ソフト

- ウィルスソフトはマルウェアを検知してブロックする
- ウィルスの検知方法
 - **ビヘイビア法**：（ビヘイビア：態度・振る舞い）メモリ上の仮想環境で検査対象のプログラムを実際に動かし、その挙動からマルウェアを検知する。未知ウィルスの検知も可能。※誤った検知をすることもある
 - **パターンマッチング法**：既存のウィルスのパターン（シグネチャコード）と検査対象プログラムを比較してマルウェアを検知する。未知ウィルスの検知は不可能

- サーバー攻撃の種類

- パスワードクラック：パスワードを見破る攻撃

- 辞書攻撃：パスワードに何かしら単語を使用する人が多いことを悪用し、辞書に載っている単語でパスワードを推測する手法
- ブルートフォース攻撃/総当たり攻撃：IDを1つ定め、パスワードとして使用可能な文字を総当たりで試す手法
- リバースブルートフォース攻撃：パスワードを1つ定め、IDとして使用可能な文字を総当たりで試す手法
- パスワードリスト攻撃：他のサイト等で不正に入手したパスワードとIDを用いてログインを試す手法。IDとパスワードを複数のサイトで使いまわす人を狙った攻撃
- レインボー攻撃：不正に入手したパスワードのハッシュ値（あるデータを特定のアルゴリズム（ハッシュ関数）で変換したもの（データ⇒ハッシュ値〇、不可逆））から元のパスワードを推測する手法

- 脆弱性を狙う攻撃：OSやWebサイトの脆弱性を狙って実施される攻撃

- クロスサイトスクリプティング：正規のWebサイト上に偽のWebページを表示させる手法。問い合わせフォーム等の偽サイトを表示して利用者に個人情報を入力させることで情報を抜き取る
- SQLインジェクション：（インジェクション：注入）SQLの中に不正な命令を紛れ込ませ、データベースを不当に操作する手法。データの漏洩やデータベースの破壊等の被害が想定される
 - 被害を防ぐ方法：入力された文字が、データベースへの問い合わせや操作において、特別な意味を持つ文字として解釈されないようにする
 - 入力者が使用したシングルクォーテーションはSQLの命令と判断されないように設定する
 - シングルクォーテーションを、ダブルクォーテーションに変換する方法も有効（エスケープ処理）
- OSコマンドインジェクション：ユーザーがWebサイトに入力したデータにOSへの命令文（コマンド）を紛れ込ませる手法。OS操作コマンド（ファイルの削除や書き換え等）を不正操作され、情報漏洩等に繋がる
- ディレクトリリステイング：Webサイトを構成するディレクトリやファイルの一覧をすべて表示させる攻撃（ユーザーに公開していないファイルも表示されてしまう）
- ディレクトリトラバーサル：（トラバーサル：横断、縦走、走査）Webの非公開ファイルに不正にアクセスし、ファイルの閲覧や削除などを実施する攻撃

- なりすまし攻撃：攻撃者が正規利用者になりすまし、情報等を騙し取る攻撃

- DNSキャッシュポイズニング：ドメインとIPアドレスを結びつけるDNSサーバーに偽サイトのドメインを紛れ込ませ、利用者を偽サイトに誘導する手法
- フィッシング：金融機関などを装った電子メールを送信して偽サイトに誘導し、使用者から個人情報を抜き取る手法
- セッションハイジャック：利用者がWebサイトにログインした際に発行されるセッションIDをはく奪し、そのIDを用いて利用者になりすます手法
 - セッション：Webページにアクセスしたユーザーが行う一連の操作（ログイン～ログアウトまで等）
 - セッションID：セッションごとに割り振られた番号で、そのセッションIDを盗み取ることで不正にログインできてしまう
- SEOポイズニング（Search Engine Optimization）：SEO（Webサイトの掲載順位を決定するアルゴリズム）を悪用し、悪意のあるWebサイトが検索上位に表示されるようにすること（Googleで某銀行を検索したが一番上に出てきたのは偽サイト）
- IPスプーフィング：攻撃者のIPアドレスを正規のアドレスに詐称してサイトに不正アクセスする手法

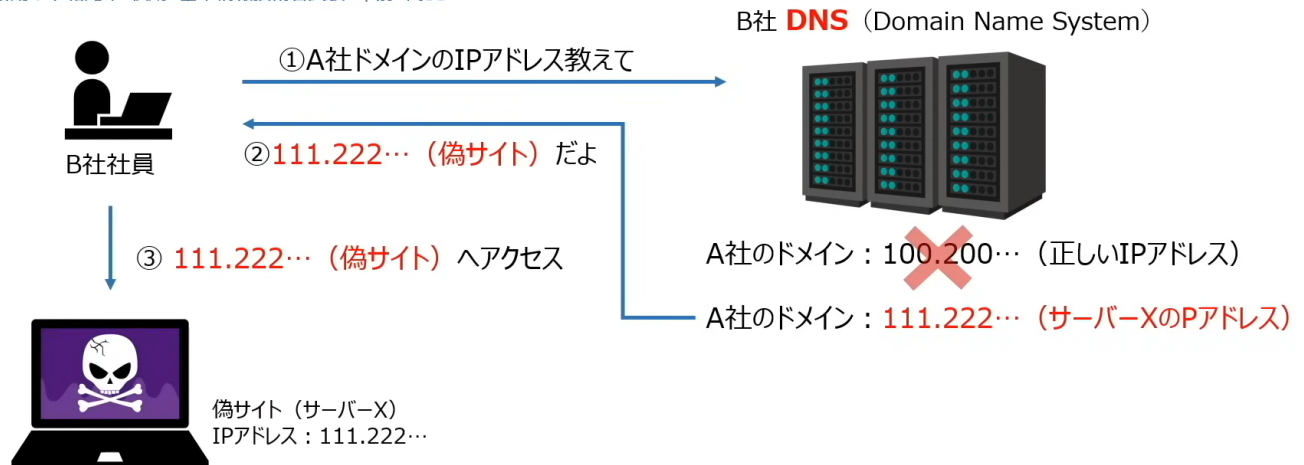
- パソコンへの攻撃：パソコンやサーバーに対して負荷やマルウェアを送り込む攻撃

- **ドライブバイダウンロード**：Webサイトを閲覧しただけでマルウェアを閲覧者のPCにダウンロードさせる手法
- **バッファオーバーフロー**：サーバーの**処理能力を超える大容量データ**等を送り付け、サービスを停止させる攻撃
- **Dos攻撃**：特定のWebサイトに対して**大量のアクセス**を行い、サーバー機能を停止させること（攻撃者PCが1台）
- **DDos攻撃**：特定のWebサイトに対して**大量のアクセス**を行い、サーバー機能を停止させること（攻撃者PCが複数台）

パスワードクラック	脆弱性を狙う攻撃	なりすまし攻撃	パソコンへの攻撃
- 辞書攻撃 - ブルートフォース攻撃 - リバースブルートフォース攻撃 - パスワードリスト攻撃 - レインボー攻撃 	- クロスサイトスクリプティング - SQLインジェクション - OSコマンドインジェクション - ディレクトリリステイング - ディレクトリトラバーサル 	- DNSキャッシュポイズニング - フィッシング - セッションハイジャック - SEOポイズニング - IPスプーフィング 	- ドライブバイダウンロード - バッファオーバーフロー - DoS攻撃 - DDoS攻撃 
パスワードを見破る攻撃	OSやWebサイトの脆弱性を狙って実施される攻撃	攻撃者が正規利用者になりすまし情報等を騙し取る攻撃	パソコンやサーバに対して負荷やマルウェアを送り込む攻撃

問35 攻撃者が用意したサーバ X の IP アドレスが、A 社 Web サーバの FQDN に対応する IP アドレスとして、B 社 DNS キャッシュサーバに記憶された。これによって、意図せずサーバ X に誘導されてしまう利用者はどれか。ここで、A 社、B 社の各従業員は自社の DNS キャッシュサーバを利用して名前解決を行う。

引用：令和元年・秋期 基本情報技術者試験 午前 問35



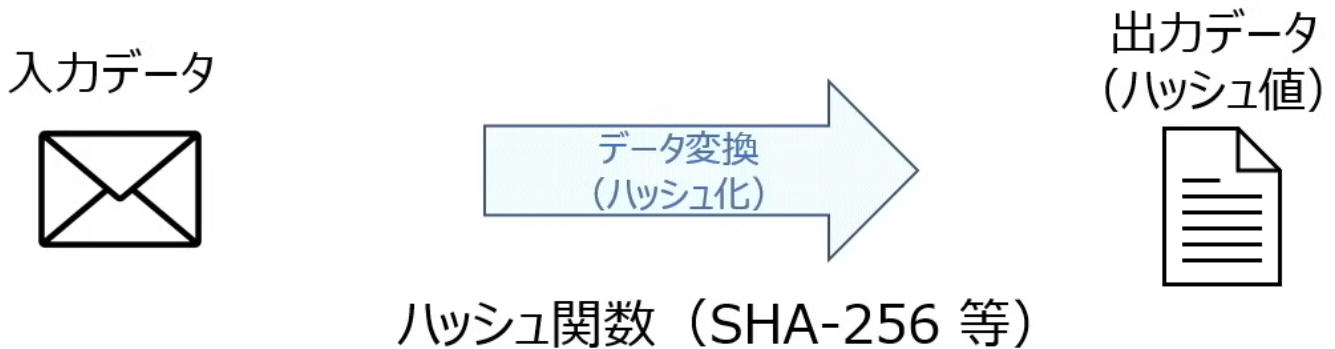
暗号化とデジタル署名

- ネットワークを用いたデータのやり取りでは「盗聴・改ざん・なりすまし」の危険がある
 - 盗聴：データのやり取りを盗み読まれること
 - 改ざん：データをやり取り中に改ざんされること
 - なりすまし：第三者が正当な人物になりすましてデータをやり取りすること
- 暗号化（盗聴を防ぐ手法）
 - 暗号化によるデータ送信し、鍵を使って復号する
 - 鍵：数学的アルゴリズムで作成された数字の羅列
 - 鍵をかける：数字を使ってデータを変形させること
 - 暗号化の方法
 - 共通鍵暗号方式：暗号化と復号で同じ鍵を使用し、鍵を秘密にしておく
 - 暗号化と復号で同じ鍵を使用し、その鍵を秘密にしておく
 - 送信側と受信側は同じ1本の鍵を使う
 - 秘密鍵の管理が困難
 - 公開鍵暗号方式：暗号化と復号で別々の鍵を使用し、暗号化用の鍵を公開する
 - 鍵Aで暗号化されたデータは鍵A'でしか復号できない
 - 暗号化用の鍵が公開されても復号化の鍵が秘密になっていれば問題ない
 - 受信者公開鍵で暗号化
 - 送信者が増えても鍵の数が増えず管理が簡単
 - 暗号化の仕組みが複雑であり、暗号化や復合に時間が要する

-	共通鍵暗号方式	公開鍵暗号方式
仕組み	暗号化と復号で同じ鍵を使用し、その鍵を秘密にしておく	暗号化と復号で別々の鍵を使用し、暗号化用の鍵を公開する
暗号アルゴリズム	AESなど	RSA、楕円曲線暗号など
メリット	処理速度が速い	鍵の管理が容易
デメリット	鍵の管理が煩雑	処理速度が遅い

- ハッシュ関数（改ざん防ぐ手法）
 - メッセージダイジェスト
 - ハッシュ関数と呼ばれるデータ変換アルゴリズムを用いることでデータの改ざんを防ぐ
 - 入力データにハッシュ関数（SHA-256）を利用して出力されたデータはハッシュ値
 - 特徴
 - 入力データに対し必ず唯一の出力データが生成される
 - 同じハッシュ関数を使用する場合、入力データから得られるハッシュ値に等しい
 - 出力データから入力データの変換はできない
 - 二つの出力データが同じ場合、ハッシュ化前は100%同じデータ

- この特徴を利用して改ざんを防ぐ
 - ハッシュ関数を用いた改ざん防止の仕組み
 1. 送信側：本来のデータと一緒にハッシュ値データを送付する
 2. 受信側：受け取ったデータをハッシュ化してみて、送られてきたハッシュ値と一致するか確認

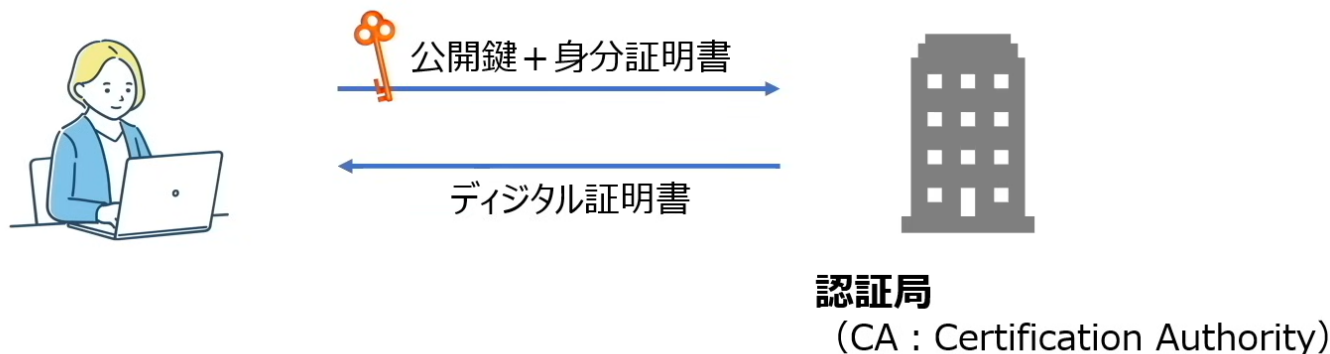


- デジタル署名（改ざん・なりすましを防ぐ手法）
 - ハッシュ化及び公開暗号方式の逆手順でデジタル署名を実施することで改ざんとなりすましを防ぐ
 - デジタル署名の仕組み
 - 送信者の秘密鍵・公開鍵を用意する
 - 送るデータのハッシュ値を用意する
 - さらにハッシュ化されたデータを、送信者の秘密鍵で暗号化する
 - 暗号化されたデータと元データを送信する
 - 受信者
 - 元データをハッシュ化
 - 送信者の秘密鍵で暗号化されたハッシュ値を送信者の公開鍵で復号
 - ハッシュ化したデータと公開鍵によって復号化されたハッシュ値が一致しているかどうか
 - 送信者の公開鍵で復号できた = 送信者の秘密鍵Aで暗号化された = なりすましではない
 - 公開暗号方式：データを安全に送るため、受信者の公開鍵で暗号化
 - デジタル署名：送信者の本人確認をするため送信者の秘密鍵で暗号化



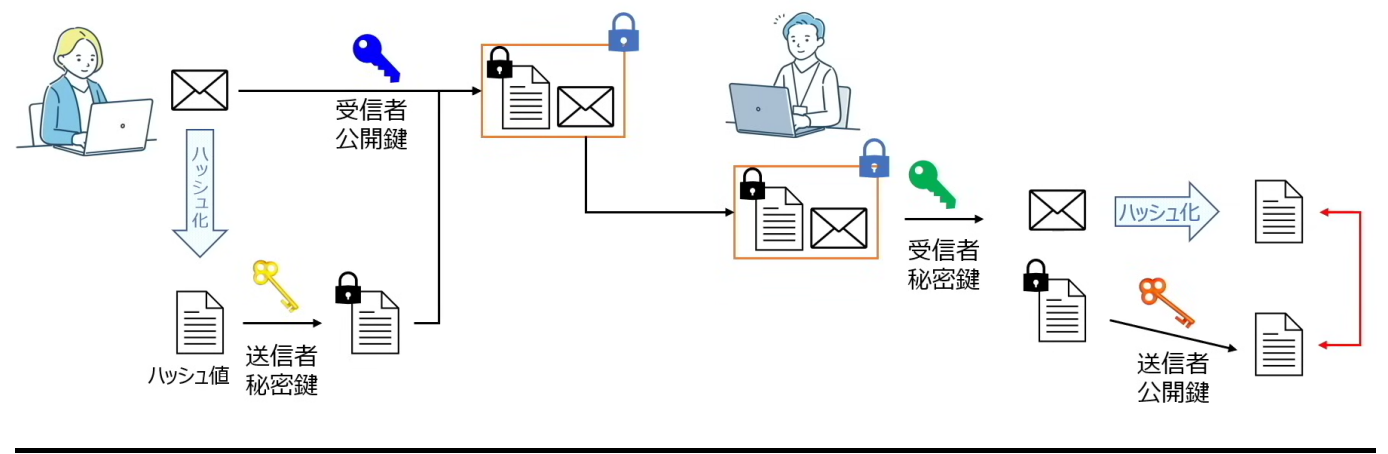
- 認証局とPKI（公開鍵基盤）

- 公開鍵が本人のものであることを証明する認証機関を認証局（CA: Certification Authority）
 - 公開鍵基盤、PKI(Public Key Infrastructure)承認期間や公開鍵暗号化技術を用いて安産に通信を行う仕組み



- 応用：デジタル署名と暗号化

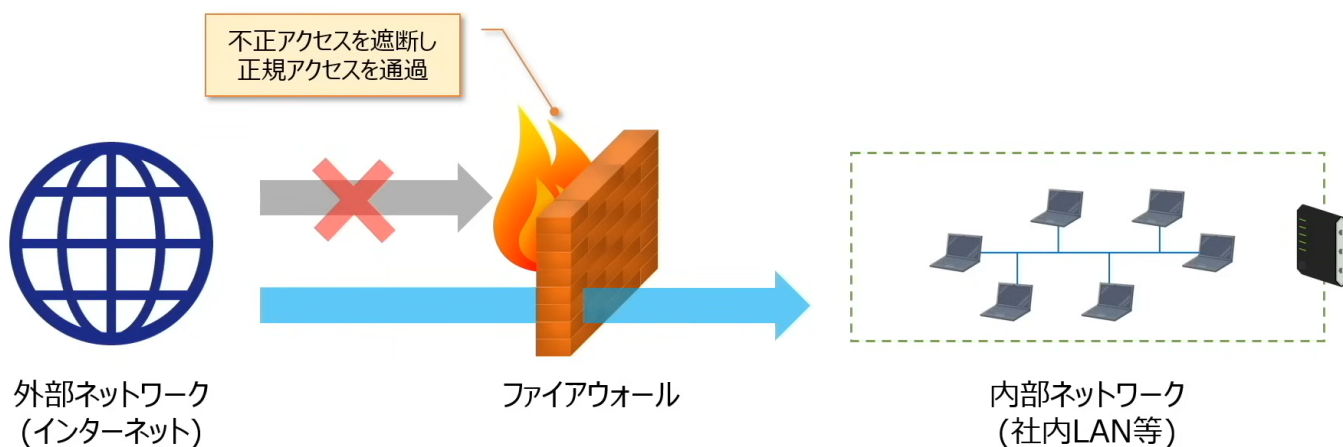
- デジタル署名と暗号化を組み合わせることで「盗聴・改ざん・なりすまし」をすべて防げるようになる
 - 送信者の秘密鍵・送信者の公開鍵
 - 受信者の公開鍵・受信者の秘密鍵
 - 送信者
 - データをハッシュ化させて、送信者の秘密鍵で暗号化（デジタル署名）
 - データを更に受信者の公開鍵で暗号化し送信
 - 受信者
 - 受信者の秘密鍵でデータを復号し、元データと暗号化されたハッシュ値を取得（公開鍵暗号・盗聴防止）
 - 元データをハッシュ化し、送信者の公開鍵でデータを復号する（デジタル署名・なりすまし防止）
 - ハッシュ化したデータと復号したハッシュ化したデータと照らし合わせする（改ざん防止）



📖 ネットワークセキュリティ

• ファイアウォール

- 内部ネットワークと外部ネットワークの間で機能する、外部からの不正アクセスを防ぐ仕組み

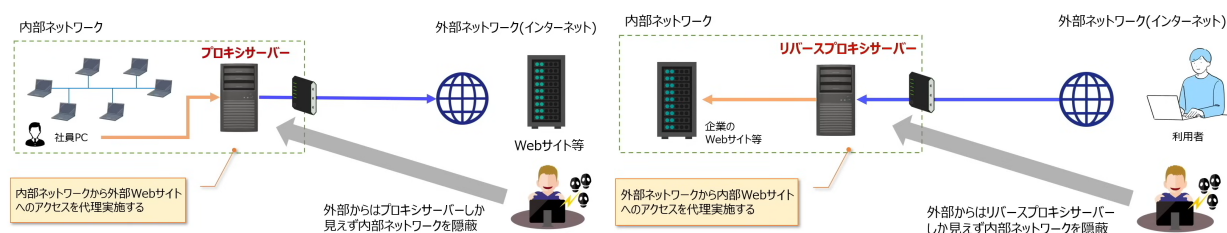


• パケットフィルタリング

- ファイアウォールの仕組みの1つであり、パケットのヘッダ情報で通信可否を制御する方法
 - パケットはヘッダ部分とデータ部分があり、ヘッダ部分には送信元IPアドレス・宛先IPアドレス・送信元ポート番号・宛先ポート番号
- パケットフィルタリングを持つ機器はフィルタリングテーブルと言う表があり、通過を許可するIPアドレスやポート番号が記載されている
- 通過許可IPアドレスを設定：ホワイトリスト
- 通過禁止IPアドレスを設定：ブラックリスト

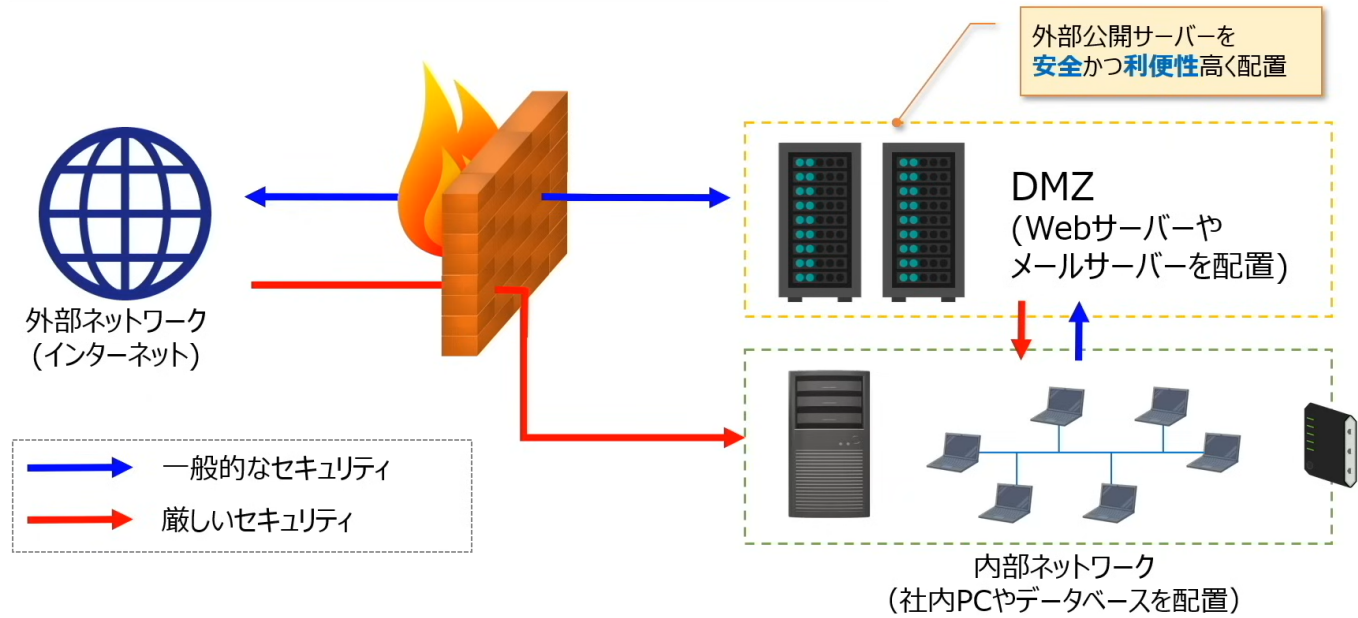
• プロキシサーバー/リバースプロキシサーバー

- プロキシ：代理
- 内部から外部へのアクセスを代理実施するサーバーをプロキシサーバーと呼ぶ
- 外部から内部へのアクセスを代理実施するサーバーをリバースプロキシサーバーと呼ぶ



• DMZ (DeMilitarized Zone、非武装地帯)

- 内部・外部から切り離されたネットワークをDMZと呼び、自社サイトのWebサーバーなど外部に公開するサーバーを設置
- 外部公開サーバーを安全かつ利便性高く配置



- WAF (Web Application Firewall)
 - Webアプリケーションへの攻撃を防ぐ仕組み
- 利用者認証技術
 - 利用者が正規の人物であることを認証する方法として以下のような手法がある
 - バイオメトリクス認証：(Biometric：生体認証) 指紋認証、顔認証、音声認証など身体的特徴を用いて本人確認をする方法
 - ワンタイムパスワード：一定時間ごとに発行され、一度きりしか使用出来ないパスワード（一回しか使用しないため、仮にパスワードを盗まれても問題ない）
 - CAPTCHA/ reCAPTCHA：コンピューターでは識別不可能な文字や画像をユーザーに回答させ、ユーザーがコンピューターbotではないことを証明する方法
 - CAPTCHA：ごによごによの文字は何を書いてる？なやつ
 - reCAPTCHA：どこに信号機があるのか？なやつ
- その他のセキュリティ対策
 - VPN(Virtual Private Network)：ネット回線上に特定の人だけがアクセスできる仮想的な専用機を引き、通信の安全性を高める方法
 - SSL (Secure Sockets Layer)：インターネットの通信を暗号化するプロトコルであり、クレジットカード等の機密情報を送る際に使用される（※ SSLの次世代規格をTLSと呼び、あまり区別されない）
 - ペネトレーションテスト：(Penetration：浸透/ 侵入) システムの脆弱性を検知するため、システムに対して実際に攻撃を仕掛け、セキュリティレベルをチェックすること（攻撃する人をホワイトハッカーと呼ぶ）
 - ファuzzing：(Fuzz：毛羽/ 綿毛 ⇒ けばだたせる/ ぼやけさせる) ソフトウェアの脆弱性を検知するため、プログラムに対して異常を引き起こす可能性がある多様なデータを自動入力してチェックすること

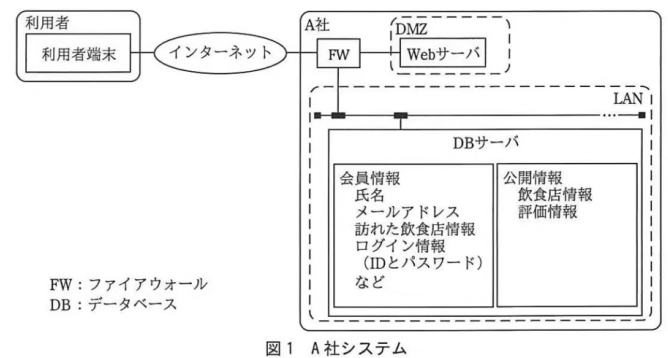
対策	チェックする場所	検査手法	効果
ペネトレーションテスト	サーバーやネットワーク	実際に攻撃を仕掛ける	システムの脆弱性や設計不備を検知する

対策	チェックする場所	検査手法	効果
ファジング	ソフトウェア	多様なデータを送る	ソフトウェアの脆弱性を検知する
• 情報セキュリティに関するプロトコル			
セキュリティ対策無し		セキュリティ対策あり	
HTTP Webサーバーとブラウザ間で情報を通信する際に使用されるプロトコル		HTTPS HTTP over SSL/TLSの略で、SSL/TLSを用いてHTTP通信を暗号化したプロトコル	
IP TCP/IPモデル第2層で使用され、データを正しいアドレスに送るためのプロトコル		IPsec IPプロトコルを拡張し暗号化を実現するプロトコル	
TELNET 現在のコンピューターから別のコンピューターを遠隔操作するプロトコル		SSH 現在のコンピューターから別のコンピューターを暗号化通信で安全に遠隔操作するプロトコル	

📖 ネットワークセキュリティ過去問演習

問1 Web サーバに対する不正侵入とその対策に関する次の記述を読んで、設問に答えよ。

A 社は、口コミによる飲食店情報を収集し、提供する会員制サービス業者である。会員制サービスを提供するシステム（以下、A 社システムという）を図1に示す。



なお、外部から Telnet や SSH で Web サーバに接続して、インターネットを介したりリモートメンテナンスが行えるようにしてあるが、現在はリモートメンテナンスの必要性はなくなっている。 ※(8)の続き

ある日、システム管理者が、ログの確認において、通常とは異なるログが記録されているのを発見した。そのログを詳しく調査したところ、システム管理者以外の者が管理者 ID と管理者パスワードを使って Web サーバに不正侵入したことが明らかになった。

そこで、システム管理者は上司と相談し、会員制サービスを直ちに停止した。次に、今回の不正侵入に対する被害状況の特定と対策の検討を行った。不正侵入による被害状況と対策の一部を抜粋したものを表1に示す。

表1 不正侵入による被害状況と対策（抜粋）

被害状況	対策
Web サーバへの不正侵入があったことが確認された。秘密鍵への不正アクセスがあったかは確認できなかった。	a
FW を経由し、Web サーバに不正侵入され、さらにそこから DB サーバに不正侵入された。	b
一部の会員については会員情報が漏えいしたことが分かっているが、それ以外の会員については漏えいの有無を特定できていない。	c

引用：平成28年・春期 基本情報技術者試験 午後 問1

• 答え：

- (1) FW、Web サーバ及び DB サーバがあり、スマートフォンなどの利用者端末とはインターネットを介して接続されている。
- (2) Web サーバは DMZ に置かれており、DB サーバは LAN に置かれている。また、利用者端末から Web サーバへの接続には、セキュリティを考慮して TLS を用いている。
- (3) 会員登録を行った利用者（以下、会員という）には、ID とパスワードが発行される。
- (4) DB サーバには、会員情報（氏名、メールアドレス、訪れた飲食店情報、ログイン情報（ID とパスワード）など）と公開情報（飲食店情報、評価情報）が保管されている。
- (5) 会員は、公開情報を閲覧することができる。また、Web サーバにログインすることで、DB サーバに保管してある自分の会員情報と自らが書き込んだ公開情報の更新、及び新しい公開情報の追加が行える。
- (6) 非会員は、公開情報の閲覧だけができる。
- (7) 会員が Web サーバにログインするには、ID とパスワードが必要であり、A 社システムは DB サーバに保管してあるログイン情報を用いて認証する。
- (8) Web サーバ及び DB サーバでは、それぞれでアクセスログ（以下、ログという）が記録されており、システム管理者が定期的に内容を確認している。また、システム管理者は、通常、LAN から Web サーバや DB サーバにアクセスして、メンテナンスを行っている。

a に関する解答群

- ア TLS を使用していても不正侵入が行われたことから、TLS の使用を直ちに中止し、通常の HTTP で通信を行う。
- イ 新たな秘密鍵と公開鍵を生成し、その鍵に対する公開鍵証明書の発行手続を行う。
- ウ 公開鍵証明書の再発行手続を行い、同じ秘密鍵を使用する。
- エ 秘密鍵へのアクセスが確認できていないことから、秘密鍵の変更や公開鍵証明書の再発行は行わず、念のため秘密鍵の保管場所を、ネットワーク経由でアクセスできないディレクトリに変更する。

b に関する解答群

- ア Telnet や SSH 以外に HTTP も利用できるようにするために、HTTP のポートを開放する。
- イ インターネットからのアクセスを FW で禁止し、Telnet や SSH のポートは閉じる。
- ウ システム管理者がどこからでもすぐに A 社システムのメンテナンスができるように、Telnet や SSH のポートの開放は継続する。
- エ パスワードや A 社システムの実装情報の漏えいを防ぐために、Telnet のポートは閉じ、SSH に限定してポートを開放する。

c に関する解答群

- ア 管理者パスワードは変更し、全会員にパスワードの変更を依頼する。
- イ 管理者パスワードは変更し、漏えいした会員だけにパスワードの変更を依頼する。
- ウ 管理者パスワードはそのままにし、全会員にパスワードの変更を依頼する。
- エ 管理者パスワードはそのままにし、漏えいした会員だけにパスワードの変更を依頼する。